

Name: Neel Pankaj Soni

Student ID: 1259189

## 1: Application and Initial Description

For this assignment, I have selected to analyze a **Peer-to-Peer (P2P) Mobile Payment Application**.

The specific application scenario I have developed for this analysis is called "**LetsPayMate**".

"LetsPayMate" is a hypothetical mobile application that allows users to instantly send and receive money using only a friend's phone number or email address. It's designed for ease of use in everyday situations like splitting a restaurant bill, sharing rent, or sending a gift.

### Key Features:

1. **User Registration & Identity Verification (KYC):** Users link their mobile number/email and a bank account or debit/credit card. To comply with financial regulations, they must verify their identity by submitting a government-issued ID (e.g., driver's license) and a selfie.
2. **Contact Integration:** The app accesses the user's phone contacts to find other "LetsPayMate" users easily.
3. **Transaction Processing:** Core P2P payments.
4. **Transaction History:** A log of all past transactions.
5. **Loyalty & Rewards:** Users can earn points for transactions, which can be redeemed for discounts.
6. **In-App Support & Notifications:** Push notifications for transaction alerts and in-app customer support chats.

### Identified Data Types (15-30 Relevant Types):

Based on this scenario, here is a list of data types "LetsPayMate" would collect.

| Category | Data Type | Description | Personal / Non-Personal |
|----------|-----------|-------------|-------------------------|
|          |           |             |                         |

|                                    |                            |                                                           |                         |
|------------------------------------|----------------------------|-----------------------------------------------------------|-------------------------|
| <b>Identity Data</b>               | Full Name                  | From user profile and ID verification.                    | Personal                |
|                                    | Government ID              | Scan of passport, driver's license, etc.                  | Sensitive Personal      |
|                                    | Biometric Data             | Selfie for liveness check during KYC.                     | Sensitive Personal      |
|                                    | Date of Birth              | From user profile and ID.                                 | Personal                |
|                                    | Photograph                 | Profile picture (optional).                               | Personal                |
| <b>Contact &amp; Account Data</b>  | Mobile Phone Number        | Primary identifier for the account.                       | Personal                |
|                                    | Email Address              | Secondary contact and identifier.                         | Personal                |
|                                    | Device Contacts            | To find friends on the platform.                          | Personal                |
|                                    | Bank Account Number        | Linked for transfers.                                     | Sensitive Personal      |
|                                    | Payment Card Details (PAN) | Card number, expiry, CVV (tokenized).                     | Sensitive Personal      |
| <b>Financial Data</b>              | Transaction Amount         | The value of a payment.                                   | Personal                |
|                                    | Transaction Timestamp      | Date and time of the payment.                             | Personal                |
|                                    | Transaction Counterparty   | Who the payment was sent to/received from.                | Personal                |
|                                    | Transaction Memo/Note      | User-entered description (e.g., "for pizza").             | Personal                |
|                                    | Wallet Balance             | Current balance in the "LetsPayMate" wallet.              | Personal                |
| <b>Technical &amp; Device Data</b> | Device ID                  | Unique identifier for the mobile device.                  | Personal (Pseudonymous) |
|                                    | IP Address                 | Used for security and location approximation.             | Personal                |
|                                    | Geolocation Data           | Approximate location derived from IP or GPS (if granted). | Personal                |

|                         |                          |                                                    |              |
|-------------------------|--------------------------|----------------------------------------------------|--------------|
|                         | App Crash Logs           | Technical data to debug application errors.        | Non-Personal |
|                         | OS Version & Type        | e.g., iOS 17.0 or Android 14.                      | Non-Personal |
| Behavioral & Usage Data | Login Timestamps         | Records of when a user accesses the app.           | Personal     |
|                         | Feature Usage Patterns   | Which features are used most (e.g., "Split Bill"). | Personal     |
|                         | Customer Support Queries | Transcripts of chats with support.                 | Personal     |
| Marketing & Preferences | Marketing Preferences    | User's choices for receiving promotional emails.   | Personal     |
|                         | Loyalty Points Balance   | Number of reward points accrued.                   | Personal     |

## 2: Data Collection Tools & Mechanisms

This section investigates and documents *how* "LetsPayMate" collects the data types we identified. The collection mechanisms are a mix of direct user input, automated SDKs, platform APIs, and backend services.

### Data Collection Mechanisms for "LetsPayMate":

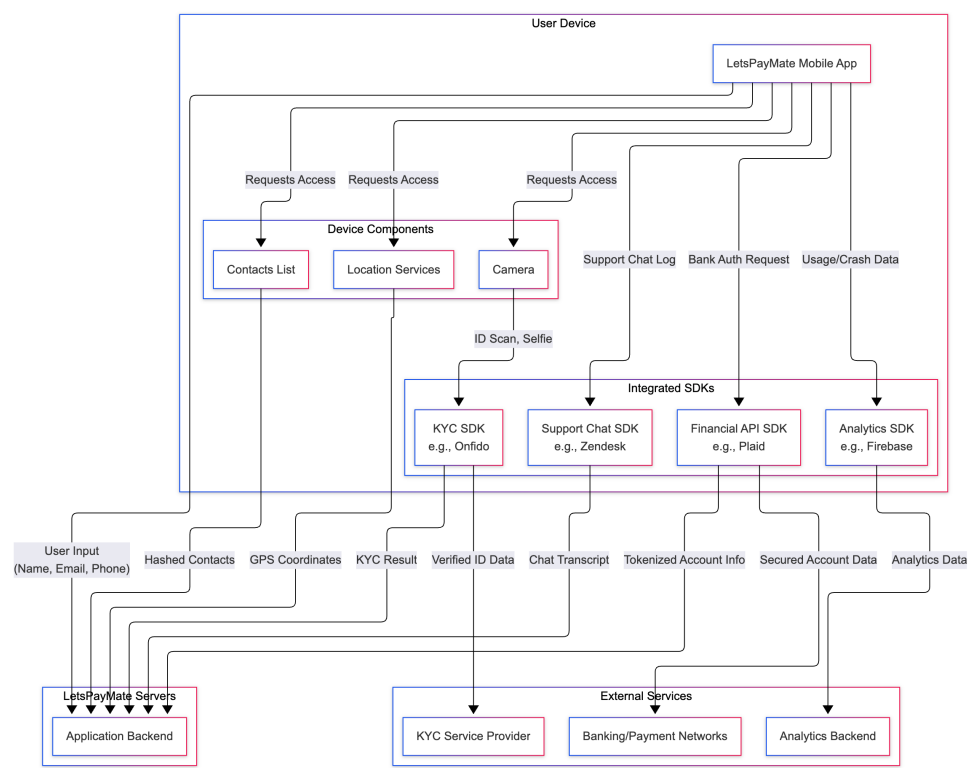
| Data Category               | Primary Data Types                               | Collection Mechanism & Tools                              | Description                                                                                  |
|-----------------------------|--------------------------------------------------|-----------------------------------------------------------|----------------------------------------------------------------------------------------------|
| Direct User Input           | Full Name, Email, Phone Number, Transaction Memo | In-App Forms & UI                                         | User manually enters this information during registration and when initiating a transaction. |
| Identity Verification (KYC) | Government ID, Biometric Data (Selfie)           | Device Camera & Third-Party KYC SDK (e.g., Onfido, Jumio) | The user is prompted to capture photos of their ID and a live selfie. The KYC SDK handles    |

|                                  |                                                                           |                                                                                              |                                                                                                                                               |
|----------------------------------|---------------------------------------------------------------------------|----------------------------------------------------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------|
|                                  |                                                                           |                                                                                              | the image upload, verification, and liveness detection.                                                                                       |
| <b>Financial Linkage</b>         | Bank Account Number, Payment Card Details                                 | Third-Party Financial API (e.g., Plaid, Stripe)                                              | User is redirected to a secure flow to authenticate with their bank or card issuer. The API securely retrieves the necessary account details. |
| <b>Social Graph</b>              | Device Contacts                                                           | Mobile OS Address Book API (Contacts Permission)                                             | The app requests permission to access the phone's contact list to find other "LetsPayMate" users.                                             |
| <b>Technical &amp; Analytics</b> | Device ID, IP Address, OS Version, App Crash Logs, Feature Usage Patterns | Mobile OS APIs & Analytics SDKs (e.g., Google Analytics for Firebase, Apple's App Analytics) | Automatically collected by the operating system and integrated SDKs for functionality, security, and analytics.                               |
| <b>Location Data</b>             | Geolocation Data                                                          | Mobile OS Location Services (GPS) & IP Geolocation                                           | Precise location requires user permission via GPS. Approximate location can be inferred from the user's IP address on the server-side.        |
| <b>Operational &amp; Support</b> | Customer Support Queries                                                  | In-App Chat SDK (e.g., Zendesk, Intercom)                                                    | Facilitates communication between the user and                                                                                                |

|                                    |                                                                      |                           |                                                                                                                               |
|------------------------------------|----------------------------------------------------------------------|---------------------------|-------------------------------------------------------------------------------------------------------------------------------|
|                                    |                                                                      |                           | support staff, logging all interactions.                                                                                      |
| <b>Transactional &amp; Backend</b> | Transaction Amount,<br>Timestamp,<br>Counterparty,<br>Wallet Balance | Backend Server Processing | This data is generated and logged as a core function of the application's backend infrastructure when a payment is processed. |

Visualization: High-Level Data Collection Architecture

To complement the table, here is a diagram that visually represents how these tools and mechanisms interact to collect data. This forms the initial part of the broader data flow.



Narrative Explanation of the Collection Architecture:

The data collection process for "LetsPayMate" begins on the **User Device**. The user provides core profile information like name and email directly through the app's interface (**In-App Forms**).

- **For Identity Verification**, the app uses the device's **Camera** in conjunction with a specialized **KYC SDK**. This SDK manages the complex process of capturing, encrypting, and transmitting the ID document and selfie to a third-party verification service, which then returns a simple "verified" or "failed" result to the "LetsPayMate" backend.
- **To Link Financial Accounts**, the app leverages a **Financial API SDK**. This tool opens a secure connection to the user's bank, allowing them to authenticate directly without sharing their banking password with "LetsPayMate". The SDK returns a secure token representing the account.
- **For Social Features**, the app requests permission to access the **Device Contacts** via the mobile OS's API. To preserve privacy, a common practice is to hash the contact information (like phone numbers) on the device before sending it to the backend to be matched against existing users, never storing the raw contact list.
- **Technical and Behavioral Data** is collected automatically by **Analytics SDKs**. These track app stability (crashes), feature usage, and general engagement, sending this data to their respective backends for processing and reporting.
- **All collected data** ultimately consolidates within the "**LetsPayMate**" **Application Backend**, where it is stored, processed for transactions, and managed.

The accompanying diagram provides a visual synthesis of these interconnected collection mechanisms, illustrating the flow of data from the user device through various integrated services and ultimately to the "LetsPayMate" backend. This architecture underscores the application's reliance on a distributed ecosystem of tools to deliver its service, each introducing distinct points for privacy consideration.

### 3: Privacy Risks and Threat Modeling

A structured analysis of privacy risks is fundamental to developing an effective governance framework. This section presents a privacy threat model for "LetsPayMate," identifying the key actors and their potential interactions with user data, followed by a detailed examination of the specific risks and their consequential impacts on users.

## 3.1 Privacy Threat Model

To systematically identify potential privacy failures, a threat model was constructed by cataloguing the actors that interact with the "LetsPayMate" ecosystem. These actors are categorized based on their intent and level of authorized access.

- **Legitimate Actors:**
  - **The User:** The primary data subject who owns the account, initiates transactions, and provides personal data.
  - **The Recipient/Counterparty:** Another user involved in a transaction, who necessarily receives limited information about the sender.
  - **LetsPayMate Administrators:** Internal personnel with privileged access to backend systems for legitimate purposes such as customer support, system maintenance, and regulatory compliance.
  - **Financial Partners:** Regulated banking and payment processing institutions that are integral to the transaction lifecycle.
- **Data-Driven Tools and Platforms:**
  - **Third-Party SDKs:** Services such as KYC verification, analytics, and customer support tools. While contractual partners, they represent a potential threat vector if they experience a breach or engage in data usage beyond the agreed scope.
  - **Cloud Infrastructure:** The hosting environment for application servers and databases, where the confidentiality and integrity of stored data are paramount.
- **Malicious Actors (Adversaries):**
  - **External Hackers:** Entities that attempt to exploit technical vulnerabilities to gain unauthorized access to the system and exfiltrate data.
  - **Insider Threats:** An authorized individual, such as a system administrator, who misuses their legitimate access privileges for unauthorized purposes.

- **Opportunistic Third Parties:** SDK providers that may leverage collected data for unauthorized secondary uses, such as cross-context behavioral advertising or sharing with data brokers.
- **Lateral Threats:** Individuals with physical access to a user's unlocked device, such as friends or family, who may intentionally or accidentally view sensitive information within the application.

## 3.2 Identified Privacy Risks and Impact Analysis

The interplay between the identified actors and the sensitive data handled by "LetsPayMate" gives rise to several critical privacy risks. The accompanying threat map diagram provides a high-level visualization of how threats propagate from sources to impacts, and the following analysis elaborates on these risks in detail.

### 3.2.1 Privacy Threat Model

A threat model helps us understand where potential privacy failures can occur by identifying the actors involved and their interactions with the system.

#### Key Actors in the "LetsPayMate" System:

- **Legitimate Actors:**
  - **User:** The individual who owns the account and data. They initiate transactions and manage their profile.
  - **Recipient/Counterparty:** Another user who receives a payment.
  - **LetsPayMate Administrators:** Employees with privileged access to the backend systems for support, maintenance, and compliance.
  - **Financial Partners:** Regulated entities like banks and payment processors necessary to complete transactions.
- **Data-Driven Tools & Platforms:**
  - **Third-Party SDKs:** The KYC, Analytics, and Support services. They are not inherently malicious but can become threat vectors if they misuse data or are compromised.



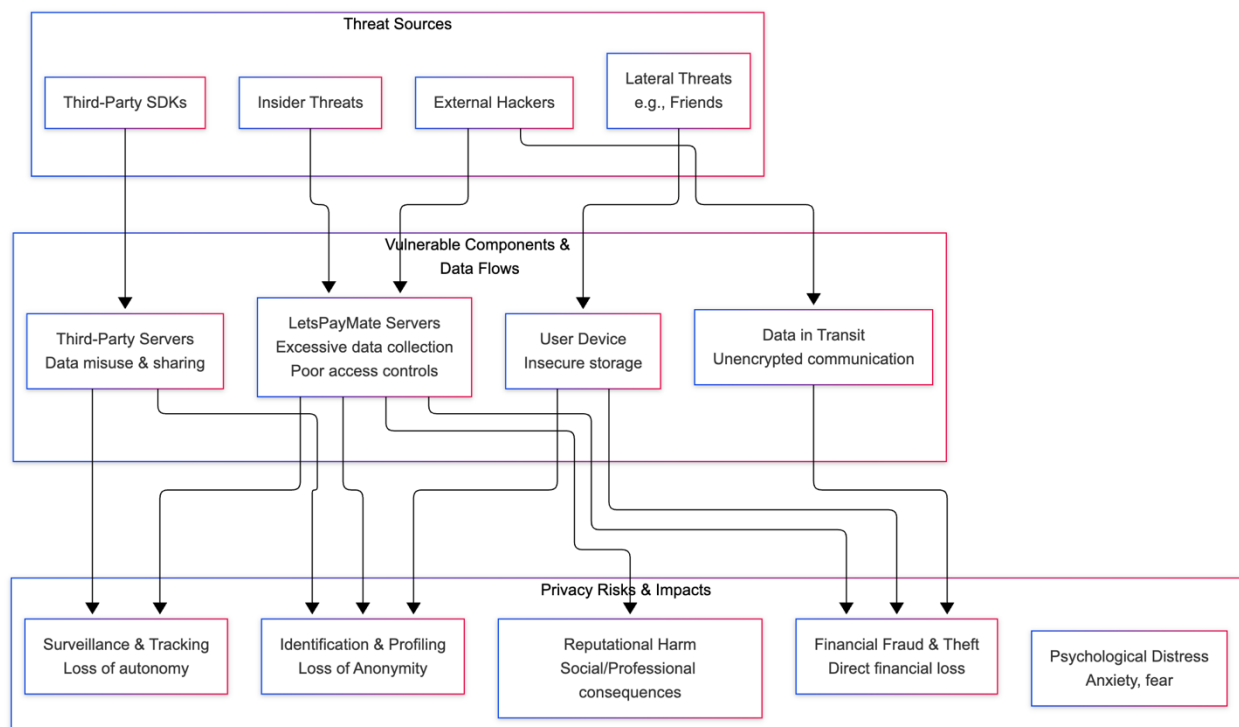
- **Cloud Infrastructure:** The servers and databases where data is stored and processed.
- **Malicious Actors (Adversaries):**
  - **External Hackers:** Individuals or groups attempting to breach the system to exfiltrate data.
  - **Insider Threats:** A rogue administrator or employee who abuses their access privileges.
  - **Data Brokers / Third Parties:** SDK providers who may use the collected data for their own purposes beyond the agreed scope (e.g., unauthorised profiling).
  - **Friends/Family (Lateral Privacy Threats):** Someone with physical access to the user's unlocked device.

### 3.2.2 Identified Privacy Risks and Impact Analysis

Using the threat model and data collection map, we can identify specific privacy risks.

#### Diagram: Privacy Threat Map

This diagram visualizes the key threats across the system's architecture.



These risks are elaborated on below table.

| <b>Threat Source</b>                        | <b>Target / Data at Risk</b>                                          | <b>Privacy Risk</b>                                                                                                                                                       | <b>Impact on User</b>                                                                                                                                                                              |
|---------------------------------------------|-----------------------------------------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>External Hackers</b>                     | Database of User Profiles, Financial Data, Government IDs             | <b>Data Breach &amp; Unauthorized Access:</b> Exploitation of vulnerabilities to steal the entire user database.                                                          | <b>Financial Fraud &amp; Theft:</b> Direct loss of funds.<br><b>Identity Theft:</b> Fraudulent loans/accounts opened using stolen ID.<br><b>Psychological Distress:</b> Anxiety and loss of trust. |
| <b>Insider Threats (Rogue Admin)</b>        | All user data, especially sensitive KYC data and transaction history. | <b>Abuse of Access Privileges:</b> Snooping on specific users' financial habits or misusing their personal data.                                                          | <b>Loss of Confidentiality:</b> Personal life exposed.<br><b>Surveillance:</b> Feeling of being watched.<br><b>Reputational Harm:</b> Leaking of sensitive transaction memos.                      |
| <b>Third-Party SDKs (e.g., Analytics)</b>   | Device ID, IP Address, Usage Patterns, Contact Hashes                 | <b>Purpose Creep &amp; Unauthorized Secondary Use:</b> SDK uses data for its own profiling, advertising, or shares it with other data brokers without clear user consent. | <b>Identification &amp; Profiling:</b> User is tracked across other apps and websites.<br><b>Loss of Anonymity:</b> Behavior is constantly monitored and analyzed.                                 |
| <b>The Application Itself (Poor Design)</b> | All collected data, especially location, contacts,                    | <b>Excessive Collection &amp; Data Hoarding:</b> Collecting more data than necessary for the service to function (e.g., precise GPS).                                     | <b>Function Creep:</b> Data collected for one purpose (e.g., KYC) is later used for another (e.g., targeted ads).<br><b>Increased Breach</b>                                                       |

|                                                    |                                                                 |                                                                                                                                                                                                                            |                                                                                                                                                                                                                                        |
|----------------------------------------------------|-----------------------------------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
|                                                    | transaction network.                                            | <b>Lack of Anonymization:</b> Storing data in a directly identifiable form indefinitely.                                                                                                                                   | <b>Impact:</b> More data is exposed if a breach occurs.                                                                                                                                                                                |
| <b>Lateral Threats</b> (Friend with device access) | Logged-in App Session, Transaction History                      | <b>Lateral Privacy Invasion:</b> Someone with temporary physical access to the unlocked phone opens the app.                                                                                                               | <b>Loss of Financial Privacy:</b> Friends/family can see transaction history and balance.<br><b>Social Conflict:</b> Disputes over past payments or financial status.                                                                  |
| <b>Data Inference</b>                              | Combined data points (e.g., transaction time, location, amount) | <b>Inference &amp; Deductive Disclosure:</b> Combining non-sensitive data to reveal sensitive information. E.g., a late-night transaction at a specific location reveals a user's health condition or relationship status. | <b>Revealing Sensitive Inferences:</b> Unintended disclosure of health, religious, or sexual orientation data.<br><b>Manipulation &amp; Discrimination:</b> Inferred data could be used for price discrimination or predatory lending. |

This threat model and risk analysis clearly demonstrate that "LetsPayMate" handles data where the consequences of privacy failure are severe, ranging from direct financial loss to profound personal and social harm.

## 4: Data Classification

To systematically prioritize privacy safeguards and security measures, a standardized data classification scheme has been applied to the data types processed by "LetsPayMate." The framework guiding this classification is derived from **NIST Special Publication 800-60, Volume I and II**, which provides a methodology for mapping information types to impact levels based on the potential

adverse consequences of a security breach, particularly concerning confidentiality. This exercise is crucial for aligning data protection efforts with the inherent sensitivity and risk associated with each data category.

## 4.1 Classification Levels

In accordance with the NIST guidelines, three distinct classification levels have been defined for the "LetsPayMate" application:

- 1. **High Sensitivity:** The unauthorized disclosure, alteration, or destruction of this data could cause severe or catastrophic adverse effects on organizational operations, organizational assets, or individuals. This includes legal, financial, and reputational harm.
- 2. **Medium Sensitivity:** The unauthorized disclosure, alteration, or destruction of this data could cause significant adverse effects.
- 3. **Low Sensitivity:** The unauthorized disclosure, alteration, or destruction of this data is expected to have a limited adverse effect.

## 4.2 Data Classification Table

The following table documents the classification of "LetsPayMate" data types, providing a clear rationale and prescribing corresponding handling requirements.

| Data Type                          | Classification Level | Rationale for Classification                                                                                                                                                                                                               | Handling & Security Requirements                                                                                                                                                                                                                                                                                         |
|------------------------------------|----------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Government ID Scan, Biometric Data | High                 | Constitutes the most sensitive personal data, directly enabling identity theft. It is irrevocable if compromised and is classified as "special category data" under regulations like the GDPR, warranting the highest level of protection. | <b>Encryption:</b> Mandatory strong encryption (e.g., AES-256) both at rest and in transit.<br><b>Access Control:</b> Strict role-based access control (RBAC) with comprehensive logging and monitoring; access granted on a strict need-to-know basis.<br><b>Storage Minimization:</b> Data must be deleted immediately |

|                                                             |               |                                                                                                                                                                                                                                                                                                |                                                                                                                                                                                                                                                                                             |
|-------------------------------------------------------------|---------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
|                                                             |               |                                                                                                                                                                                                                                                                                                | after the successful completion of the KYC verification process.<br><b>Segregation:</b> Storage in a highly secure, isolated data vault.                                                                                                                                                    |
| Bank Account Numbers, Payment Card Details                  | <b>High</b>   | Provides direct access to a user's financial assets. A breach would lead to immediate financial fraud and theft, constituting a severe impact. Compliance with the PCI-DSS standard is mandatory for this data type.                                                                           | <b>Tokenization:</b> Primary Account Numbers (PANs) must be replaced with tokens for all internal processing.<br><b>Encryption:</b> Strong encryption as mandated by PCI-DSS.<br><b>Access Control:</b> Highly restricted, with access limited to a minimal number of authorized personnel. |
| Full Name, Date of Birth, Phone Number, Transaction History | <b>Medium</b> | Directly identifies an individual and can reveal personal relationships, financial habits, and lifestyle. This data can be leveraged for phishing, social engineering, or correlated with other data to create intrusive profiles, leading to significant reputational harm or discrimination. | <b>Encryption:</b> Required at rest and in transit.<br><b>Access Control:</b> Enforced through role-based policies.<br><b>Pseudonymization:</b> Use of internal user IDs instead of direct identifiers in analytics and testing environments.                                               |
| Geolocation Data, Device Contacts                           | <b>Medium</b> | Poses significant risks to personal safety and privacy, including stalking and the unwanted exposure of one's social graph. The continuous                                                                                                                                                     | <b>Consent:</b> Explicit, granular, and freely given consent is required for collection and each specific purpose.<br><b>Purpose Limitation:</b> Data may                                                                                                                                   |

|                                       |               |                                                                                                                                                                                              |                                                                                                                                                                                                             |
|---------------------------------------|---------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
|                                       |               | collection of location data constitutes a form of surveillance.                                                                                                                              | only be used for the declared feature (e.g., finding nearby friends).<br><b>Encryption:</b> Must be applied both at rest and in transit.                                                                    |
| Device Identifiers, IP Address        | <b>Medium</b> | Serves as a persistent identifier that can track a user's activity across different services and over time, facilitating extensive profiling and erosion of anonymity.                       | <b>Pseudonymization:</b> Must be hashed or masked before any processing or use in analytics.<br><b>Minimization:</b> Should be avoided or deleted where not essential for security or core functionality.   |
| App Crash Logs, Anonymized Usage Data | <b>Low</b>    | When properly aggregated and stripped of identifiers, this data does not relate to an identified or identifiable natural person. Its compromise presents a limited risk to individual users. | <b>Aggregation &amp; Anonymization:</b> Must be processed in a truly anonymized form, ensuring non-identifiability.<br><b>Separation:</b> Stored in systems segregated from those containing personal data. |

### 4.3 Explanation of Analysis and Choices

The classification rationale is grounded in a tripartite analysis considering **regulatory mandates, potential impact on the data subject, and established industry best practices.**

- The **High Sensitivity** classification is reserved for data that serves as a direct key to an individual's core identity or financial assets. The severe, often irreversible, nature of harm resulting from a breach such as identity theft or direct financial loss dictates this stringent classification. This aligns directly with the treatment of special category data under the GDPR and the stringent controls of standards like PCI-DSS.
- The **Medium Sensitivity** category encompasses the broad spectrum of personal identifiable information (PII). The guiding principle here is that while this data may not enable immediate

financial theft, its misuse can lead to substantial harm, including sophisticated profiling, social or financial discrimination, reputational damage, and psychological distress. This classification ensures that fundamental security principles like encryption, access control, and purpose limitation are applied as a baseline to all personal data.

- The **Low Sensitivity** designation is cautiously applied only to information that is demonstrably non-personal. This enables the organization to leverage operational data for vital functions such as system monitoring and product improvement, without incurring the significant compliance overheads associated with personal data, thus adhering to the principle of data minimization by design.

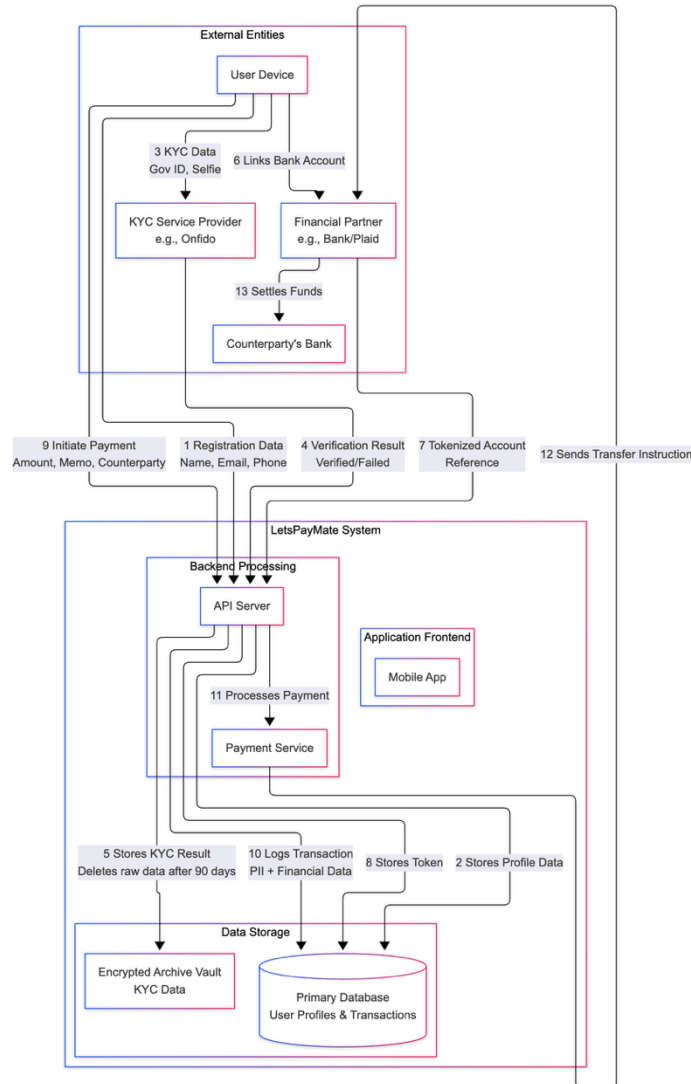
This structured classification provides a clear and defensible foundation for the subsequent development of the data governance framework and technical controls, ensuring that protective measures are commensurate with the level of risk.

## 5: Data Flow Analysis: Diagram and Narrative

A comprehensive understanding of how data traverses a system is fundamental to identifying and mitigating privacy risks. This section provides a detailed visualization and narrative explanation of the data flow within the "LetsPayMate" application, focusing on the critical user journey of registration and payment execution. The analysis follows the data from its point of collection to its eventual deletion, highlighting potential privacy vulnerabilities at each stage.

### 5.1 Data Flow Diagram (DFD)

The accompanying diagram illustrates the key processes, data stores, and external entities involved when a user registers and makes a payment with "LetsPayMate." It provides a high-level architectural view of the system's data movement.



## 5.2 Narrative Explanation of the Data Flow

The data flow can be segmented into distinct stages, each with its own processes and associated privacy considerations.

### Stage 1: Data Collection and Ingestion

This initial stage involves data entering the system directly from the user or their device (Steps 1, 3, 6, 9). The user provides registration details, submits identity documents via the camera, authenticates with their financial institution, and initiates transactions.

- Privacy Risks:** A primary risk at this stage is the potential violation of **data minimization**. The application must be designed to collect only data that is strictly necessary for the specified purpose. Furthermore, the quality of **informed consent** is critical; users may grant



permissions for contacts or location without fully comprehending the subsequent use of this data. The security of the data is also contingent on the user's device integrity, making it vulnerable to loss, theft, or malware.

## **Stage 2: Data Transmission**

This stage encompasses all data movement between systems, including between the user's device and "LetsPayMate" servers, and between "LetsPayMate" and its third-party partners (all connecting arrows in the diagram).

- **Privacy Risks:** The principal risk here is the interception of data during transmission. A failure to employ strong encryption protocols, such as Transport Layer Security (TLS), would leave data exposed to **eavesdropping** and **man-in-the-middle attacks** on unsecured networks.

## **Stage 3: Data Processing**

Within the "LetsPayMate" backend (Steps within 'Backend Processing'), data is actively used. The API Server validates KYC results and transaction requests, while the Payment Service orchestrates fund transfers. This stage also includes internal operations like analytics and customer support.

- **Privacy Risks:** This stage is vulnerable to **insider threats**, where a privileged administrator could abuse their access to snoop on sensitive user data. Another significant risk is **function creep**, where data collected for one purpose (e.g., payment processing) is repurposed for another (e.g., behavioral analytics or marketing) without obtaining fresh user consent. Additionally, as previously identified, **inference attacks** can occur when seemingly benign data points are combined to reveal sensitive information.

## **Stage 4: Data Storage**

Data persisted in various storage solutions (Steps 2, 5, 8, 10). User profiles and transactions are stored in the primary database, while highly sensitive KYC data is isolated in a separate, encrypted vault.

- **Privacy Risks:** The most severe risk at this stage is a **large-scale data breach**. The impact of such a breach is directly proportional to the volume and sensitivity of the stored data, as classified in Section 4. The effectiveness of encryption is also contingent on robust **key management**. Furthermore, storing data indefinitely, beyond the necessary retention period,

violates the principle of **storage limitation** and unnecessarily amplifies the potential impact of a future breach.

### Stage 5: Data Sharing

To deliver its core service, "LetsPayMate" must share data with external partners (Steps 4, 7, 12). This includes sending KYC data to a verification provider and payment instructions to financial partners.

- **Privacy Risks:** This introduces a **loss of direct control**. "LetsPayMate" remains accountable for user data even if a breach occurs at a third-party provider. There is also a risk of **opaque data practices**, where these partners may use the shared data for their own secondary purposes, such as profiling, beyond the user's knowledge or the original contractual agreement.

### Stage 6: Data Deletion and Archival

The final stage involves the secure disposal of data that is no longer required (Step 5). For instance, raw KYC data is deleted from the secure vault after a predefined retention period mandated by anti-money laundering regulations, while the verification result is maintained.

- **Privacy Risks:** Key risks include **incomplete deletion**, where data remnants persist in backups or logs, and **unjustified retention**, where data is kept longer than legally or operationally necessary. This directly infringes upon the user's **right to erasure** as stipulated by regulations like the GDPR.

This end-to-end analysis of the data flow provides a crucial map of the application's privacy landscape, clearly identifying where vulnerabilities can emerge throughout the data lifecycle. This detailed understanding forms the essential foundation for designing the targeted and effective Privacy Governance Framework that follows.

## References

1. Plaid. Authentication | Plaid Docs. n.d. <https://plaid.com/core-exchange/docs/authentication/>
2. Kevin Stine; Richard Kissel; William C. Barker; Jim Fahlsing; Jessica Gulick. NIST Special Publication 800-60 Volume I Revision 1: Guide for Mapping Types of Information and Information

Systems to Security Categories. August 2008.

<https://nvlpubs.nist.gov/nistpubs/legacy/sp/nistspecialpublication800-60v1r1.pdf>

3. Jumio. Online Services Privacy Notice | Jumio Privacy and Trust Center. Last updated March 31, 2024. <https://www.jumio.com/privacy-center/privacy-notices/online-services-notice/>

4. Google. Change app permissions on your Android phone. n.d. <https://support.google.com/android/answer/9431959?hl=en>

5. Stripe. Integration security guide | Stripe Documentation. n.d. <https://docs.stripe.com/security/guide>

6. OWASP Foundation. Top 10 Mobile Risks - Final List 2016. 2016. <https://owasp.org/www-project-mobile-top-10/2016-risks/>

7. Scisimple. Privacy Risks of Third-Party SDKs in Android Apps. June 11, 2025. <https://scisimple.com/en/articles/2025-06-11-privacy-risks-of-third-party-sdks-in-android-apps--a9ngej6>

8. Yifan Zhang et al. Navigating the Privacy Compliance Maze: Understanding Risks with Privacy-Configurable Mobile SDKs. USENIX. 2024. <https://www.usenix.org/conference/usenixsecurity24/presentation/zhang-yifan>

9. Austin McMichael. Understanding the Privacy Implications of SDKs | Transcend. November 14, 2023. <https://transcend.io/blog/sdk-privacy>

10. Apple. Control access to your contacts on iPhone - Apple Support. n.d. <https://support.apple.com/guide/iphone/control-access-to-contacts-iph9536aa9a5/ios>

11. PCI Security Standards Council. PCI Data Security Standard (PCI DSS). n.d. <https://www.pcisecuritystandards.org/standards/pci-dss/>

12. GDPR. Article 17 — Right to erasure. Regulation (EU) 2016/679. 2016. <https://gdpr-info.eu/art-17-gdpr>

13. Information Commissioner's Office (ICO). Right to erasure | ICO. n.d. <https://ico.org.uk/for-organisations/uk-gdpr-guidance-and-resources/individual-rights/individual-rights/right-to-erasure/>

14. Information Commissioner's Office (ICO). Principle (c): Data minimisation. n.d.  
<https://ico.org.uk/for-organisations/uk-gdpr-guidance-and-resources/data-protection-principles/a-guide-to-the-data-protection-principles/data-minimisation/>
15. Google / Firebase. Configure Analytics data collection and usage | Firebase. n.d.  
<https://firebase.google.com/docs/analytics/configure-data-collection>
16. Google Ads Help. About the customer matching process. n.d. <https://support.google.com/google-ads/answer/7474263?hl=en>
17. Federal Trade Commission. No, hashing still doesn't make your data anonymous. July 24, 2024.  
<https://www.ftc.gov/policy/advocacy-research/tech-at-ftc/2024/07/no-hashing-still-doesnt-make-your-data-anonymous>